DPIA Kitöltési Útmutató

Adatvédelmi Hatásvizsgálat (DPIA)
HR-ERP Jólléti Platform — Housing Solutions Kft.
I. MI AZ A DPIA?
1.1 Definíció
1.2 Mikor Kötelező?
1.3 Mi Történik Ha Nincs DPIA?
II. HR-ERP SPECIFIKUS DPIA KITÖLTÉSE
A. Adatfeldolgozási Műveletek Leírása
A.1 A Rendszer Célja
A.2 Adatkategóriák
A.3 Adatfeldolgozási Műveletek
A.4 Adatátvitel
A.5 Adatmegőrzési Időszakok
B. Szükségesség és Arányosság Értékelés
B.1 Jogalap
B.2 Célhoz Kötöttség
B.3 Adatminimalizálás
B.4 Arányosság — Miért Szükséges?
B.5 Alternatívák Értékelése
C. Kockázatok Azonosítása
C.1 Kockázatértékelési Mátrix
C.2 Kockázati Összefoglaló
D. Intézkedések a Kockázatok Csökkentésére
D.1 Technikai Intézkedések
D.2 Szervezési Intézkedések
D.3 Jogi Intézkedések
III. JÓVÁHAGYÁSI FOLYAMAT
3.1 Ki Hagyja Jóvá?
3.2 Mikor Kell Frissíteni?
3.3 Tárolás
IV. NAIH SABLON — Kitöltve HR-ERP Adatokkal
4.1 Alapadatok
4.2 Adatfeldolgozás Összefoglalása
4.3 Szükségességi Teszt
4.4 Maradványkockázat Értékelés
4.5 Jóváhagyás

Adatvédelmi Hatásvizsgálat (DPIA)

HR-ERP Jólléti Platform — Housing Solutions Kft.

GDPR 35. cikk szerinti dokumentum

Verzió: 1.0 | **Dátum:** 2026-03-18 | **Besorolás:** Bizalmas **Adatkezelő:** Housing Solutions Kft. | **Státusz:** Kitöltött sablon

---

I. MI AZ A DPIA?

1.1 Definíció

A GDPR 35. cikk (1) bekezdése:

> *„Ha az adatkezelés valamely — különösen új technológiákat alkalmazó — típusa a feldolgozás jellegére, hatókörére, körülményeire és céljaira tekintettel valószínűsíthetően magas kockázattal jár a természetes személyek jogaira és szabadságaira nézve, az adatkezelő az adatkezelést megelőzően hatásvizsgálatot végez arra vonatkozóan, hogy a tervezett adatkezelési műveletek a személyes adatok védelmét hogyan érintik.”*

1.2 Mikor Kötelező?

A GDPR 35. cikk (3) bekezdése és a 29-es Munkacsoport iránymutatása alapján **három fő kritérium** határozza meg a kötelezettséget. **Legalább kettő teljesülése** esetén DPIA kötelező:

#	Kritérium	Részletes Leírás	HR-ERP Platform	Teljesül?
1	**Szisztematikus értékelés**	Természetes személyek személyes jellemzőinek átfogó, szisztematikus értékelése automatizált feldolgozás alapján	Napi pulzus felmérések (hangulat, stressz, alvás), negyedéves MBI/UWES kiégés és elkötelezettség felmérések, prediktív analitika (kiégés előrejelzés)	✅ **IGEN**
2	**Különleges adatok nagy volumenben**	A GDPR 9. cikk szerinti különleges adatkategóriák	Egészségügyi adatok: hangulat pontszám (1-5), stressz szint	✅ **IGEN**

#	Kritérium	Részletes Leírás	HR-ERP Platform	Teljesül?
		nagy volumenű feldolgozása	(1-10), alvásminőség (1-10), kiégési pontszám (0-100), EAP ügyek, coaching jegyzőkönyvek	
3	**Nyilvános terület megfigyelése**	Szisztematikus, nagyszabású nyilvános területek megfigyelése	Nem alkalmazandó — zárt rendszer, nem nyilvános terület	❌ NEM

Eredmény: 2/3 kritérium teljesül → DPIA KÖTELEZŐ.

1.3 Mi Történik Ha Nincs DPIA?

Szankció	Mérték
GDPR bírság	Max 20.000.000 EUR **vagy** éves globális árbevétel 4%-a (amelyik magasabb)
NAIH bírság	100.000 Ft — 20.000.000 Ft (magyar hatóság)
Reputációs kár	Nyilvánosságra hozott NAIH határozat, ügyfélvesztés
Adatfeldolgozás felfüggesztése	NAIH elrendelheti az adatfeldolgozás azonnali leállítását

---

II. HR-ERP SPECIFIKUS DPIA KITÖLTÉSE

A. Adatfeldolgozási Műveletek Leírása

A.1 A Rendszer Célja

Az HR-ERP Jólléti Platform célja a munkavállalók jóllétének **proaktív monitorozása és támogatása** az alábbi eszközökkel:

- **WellMind modul**: Napi pulzus felmérések (hangulat, stressz, alvásminőség, munkaterhelés), negyedéves MBI (Maslach Burnout Inventory) és UWES (Utrecht Work Engagement Scale) felmérések, automatikus kiégés-felismerés és beavatkozás-javaslás, coaching menedzsment
- **CarePath modul**: Employee Assistance Program (EAP) ügykezelés, szolgáltató keresés és időpont foglalás, krízisintervenció, anoním ügyindítás lehetősége
- **Kiegészítő modulok**: Szállásminőség nyomon követése, túlóra-kiégés korreláció elemzés, betegszabadság automatikus érzékelés, munkahelyi konfliktus nyomon követés

A.2 Adatkategóriák

Kategória	GDPR Besorolás	Példák	Jogalap
Egészségügyi adat	9. cikk (különleges)	Hangulat (1-5), stressz (1-10), alvásminőség (1-10), kiégési pontszám (0-100), EAP ügyek	9(2)(a) kifejezett hozzájárulás + 9(2)(b) munkajogi kötelezettség
Személyes adat	6. cikk (általános)	Név, email, beosztás, alvállalkozó, munkaviszony adatok	6(1)(b) szerződés teljesítése
Technikai adat	6. cikk (általános)	IP cím, eszköz azonosító, böngésző user agent, session token	6(1)(f) jogos érdek

A.3 Adatfeldolgozási Műveletek

Művelet	Leírás	Gyakoriság	Érintettek Száma
Pulzus felmérés gyűjtés	Napi hangulat/stressz/alvás/munkaterhelés	Naponta	Minden aktív felhasználó
MBI/UWES felmérés	Negyedéves kiégés és elkötelezettség	Negyedévente	Minden felhasználó
Csapat aggregáció	Anonymizált csapatmetrikák számítása	Napi/heti	Min. 5 fős csoportok
Automatikus triggerek	Kiégés >70, 3+ betegszabadság, kritikus jegy	Valós idejű	Érintett felhasználók
EAP ügykezelés	Ügy létrehozás, szolgáltató foglalás, jegyzőkönyv	Eseti	Ügyet indító felhasználók
Prediktív analitika	Kiégés előrejelzés, fluktuációs kockázat	Napi batch	Minden felhasználó (aggregált)

A.4 Adatátvitel

Irány	Módszer	Biztonság	DPA
Felhasználó → Szerver	HTTPS (TLS 1.3)	End-to-end titkosítás	N/A
Szerver → Adatbázis	Belső hálózat	pgcrypto titkosítás, RLS	N/A
Szerver → Cloud (hosting)	HTTPS	AWS/GCP standard	⚠️ Szükséges
Szerver → Claude API	HTTPS	NLP elemzéshez	⚠️ Szükséges
Szerver → Email provider	HTTPS	Értesítés küldés	⚠️ Szükséges

A.5 Adatmegőrzési Időszakok

Adattípus	Megőrzési Idő	Törlés Módja
Pulzus felmérések	Aktív munkaviszony + 1 év	Automatikus cron
MBI/UWES felmérések	Aktív munkaviszony + 1 év	Automatikus cron
CarePath ügyek	Ügy lezárása + 1 év	Automatikus cron
Coaching jegyzőkönyvek	Session + 6 hónap	Automatikus cron (titkosított)
Audit napló	5 év	Manuális archiválás
Felhasználói profil	Munkaviszony megszűnése + 30 nap	Soft delete → hard delete

---

B. Szükségesség és Arányosság Értékelés

B.1 Jogalap

Jogalap	GDPR Cikk	Alkalmazás
Kifejezett hozzájárulás	9(2)(a)	Munkavállalók explicit opt-in minden adattípushoz (Consent UI)
Munkajogi kötelezettség	9(2)(b)	Mt. 166. § — munkáltató köteles biztosítani az egészséges és biztonságos munkakörülményeket
Foglalkozás-egészségügy	9(2)(h)	Munkavállalói jóllét monitorizálása és támogatása

B.2 Célhoz Kötöttség

Az adatok **kizárólag** az alábbi célokra használhatók:

✅ Megengedett Cél	❌ Tiltott Felhasználás
Munkavállalói jóllét monitorozása	Toborzási döntések
Kiégés korai felismerése és megelőzése	Teljesítményértékelés
EAP szolgáltatás nyújtása	Fegyelmi eljárás
Aggregált szervezeti insight-ok (min 5 fő)	Egyéni rangsorolás, összehasonlítás
Tudományos kutatás (anonimizált, opt-in)	Automatizált elbocsátási döntés

B.3 Adatminimalizálás

Amit GYŰJTÜNK	Amit NEM gyűjtünk
Hangulat (1-5 skála)	Biometrikus adat
Stressz szint (1-10)	Kamera/mikrofon felvétel
Alvásminőség (1-10)	GPS hely (munkaidőn kívül)
Munkaterhelés (1-10)	Érzelemfelismerés (EU AI Act tiltja)
MBI/UWES pontszámok	Webböngészési előzmények
Szabad szöveges megjegyzés (opcionális)	Privát üzenetek monitorozása

B.4 Arányosság — Miért Szükséges?

Szempont	Indoklás
Jogszabályi kötelezettség	Mt. 166. § — munkáltató köteles biztosítani az egészséges munkakörülményeket
Megelőzés hatékonysága	WHO: prevenciós programok ROI 4:1 (depresszió, szorongás kezelésénél)
Korai felismerés	Deloitte (2020): prevenciós beavatkozások ROI 5:1 – 10:1 vs. reaktív megközelítés
Nincs kevésbé invazív alternatíva	Papír alapú felmérések → alacsonyabb részvétel, lassabb elemzés, nincs automatikus korai felismerés

B.5 Alternatívák Értékelése

Alternatíva	Előny	Hátrány	Következtetés
Manuális felmérések (papír)	Nincs technológiai kockázat	Alacsony részvétel, lassú feldolgozás, nincs korai jelzés	❌ Nem elegendő

Alternatíva	Előny	Hátrány	Következtetés
Külső EAP szolgáltató	Meglévő compliance	Nincs korai felismerés, drágább, reaktív	❌ Részleges megoldás
Semmit nem tenni	Nulla költség	Mt. 166. § nem teljesítése, magasabb fluktuáció, produktivitásvesztés	❌ Jogi kockázat
HR-ERP Jólléti Platform	Proaktív, korai felismerés, integrált, ROI mérhető	GDPR compliance szükséges	✅ **Legjobb opció**

C. Kockázatok Azonosítása

C.1 Kockázatértékelési Mátrix

#	Kockázat	Leírás	Valószínűség	Hatás	Kockázati Szint
1	**Adatszivárgás**	Adatbázishoz illetéktelen hozzáférés, adatok kiszivárgása	Közepes	Magas	**MAGAS**
2	**Hozzáférés-szabályozási hiba**	Munkavállaló látja más dolgozó egyéni adatait	Alacsony	Magas	**KÖZEPES**
3	**Re-identifikáció aggregált adatokból**	Kis csoportból (<5 fő) egyén azonosítható	Alacsony	Közepes	**ALACSONY**
4	**Harmadik feles adatszivárgás**	Vendor (cloud, AI API) kompromittálódik	Közepes	Közepes	**KÖZEPES**

#	Kockázat	Leírás	Valószínűség	Hatás	Kockázati Szint
5	**Előítéletes AI döntések**	NLP hangulatelemzés torzítása → diszkrimináció	Közepes	Közepes	**KÖZEPES**
6	**Hozzájárulás érvénytelensége**	Implicit consent nem felel meg GDPR 9. cikk követelményeinek	Magas	Magas	**KRITIKUS**
7	**Túlzott adatmegőrzés**	Személyes adat törvényi határidőn túl tárolva	Alacsony	Alacsony	**ALACSONY**
8	**Nem megfelelő tájékoztatás**	Munkavállalók nem kapnak elég információt adataik felhasználásáról	Közepes	Közepes	**KÖZEPES**
9	**Profilalkotás jogellensége**	Automatikus kockázatbesorolás GDPR 22. cikk alapján	Alacsony	Magas	**KÖZEPES**
10	**Cross-border adatátvitel**	Adatok EU-n kívülre kerülnek (US cloud, US API)	Közepes	Közepes	**KÖZEPES**

C.2 Kockázati Összefoglaló

Szint	Darabszám	Kezelés
KRITIKUS	1	Azonnali kezelés (Consent UI — Tier 1)
MAGAS	1	Sürgős kezelés (adatszivárgás elleni védelemek — Kész)
KÖZEPES	6	Tervezett kezelés (DPA-k, AI audit, tájékoztatás,

Szint	Darabszám	Kezelés
		SCC)
ALACSONY	2	Elfogadható kockázat, monitorozás

D. Intézkedések a Kockázatok Csökkentésére

D.1 Technikai Intézkedések

Intézkedés	Leírás	Állapot
Adatbázis titkosítás	pgcrypto: CarePath session jegyzőkönyvek PGP titkosítása	✅ Kész
Szállítási titkosítás	HTTPS/TLS 1.3 kizárólagos, HTTP átirányítás	✅ Kész
Hozzáférés-szabályozás	PostgreSQL RLS, JWT token (15 perc expiry), role-based permissions	✅ Kész
Audit naplózás	`wellbeing_audit_log` — INSERT only, UPDATE/DELETE blokkolva triggerrel	✅ Kész
Rate limiting	API végpontok: 100 request/perc/felhasználó	✅ Kész
Adatminimalizálás	Csak szükséges mezők, nincs biometrikus/GPS/kamera adat	✅ Kész
Aggregációs védelem	Min 5 fős szabály minden csapat-szintű lekérdezésben	✅ Kész
Automatikus törlés	Cron job lejárt adatok törlésére	📋 Tervezett (Tier 2)
Differenciált adatvédelem	Laplace-zaj aggregált metrikákhoz (5-15 fős csapatok)	📋 Tervezett (Session 26)

D.2 Szervezési Intézkedések

Intézkedés	Leírás	Állapot
Hozzáférési szabályzat	Ki láthat mit — policy dokumentum	📋 Szükséges

Intézkedés	Leírás	Állapot
Alkalmazotti képzés	GDPR awareness training évente	⬜ Szükséges
Incidenskezelési terv	Data breach protokoll: 72 óra NAIH bejelentés	⬜ Szükséges
Éves DPIA felülvizsgálat	Ez a dokumentum — évente frissítendő	⬜ Folyamatos
DPO / konzulens kijelölés	250+ fő vállalatnál kötelező, egyébként ajánlott	⬜ Mérlegelés

D.3 Jogi Intézkedések

Intézkedés	Leírás	Állapot
DPA szerződések	Minden harmadik féllel (cloud, AI, email)	⚠️ Szükséges (Tier 1)
Adatkezelési tájékoztató	Magyar + angol, user-facing	⚠️ Szükséges (Tier 2)
Hozzájárulási nyilatkozat	Explicit opt-in minden adattípushoz	⚠️ Szükséges (Tier 1)
Felhasználási feltételek	Szolgáltatás igénybevételének feltételei	⬜ Szükséges (Tier 2)

III. JÓVÁHAGYÁSI FOLYAMAT

3.1 Ki Hagyja Jóvá?

Szerepkör	Felelősség	Megjegyzés
Adatvédelmi Tisztviselő (DPO)	DPIA felülvizsgálat és jóváhagyás	250+ fő vállalatnál kötelező kijelölés
Külső adatvédelmi konzulens	Szakértői értékelés ha nincs DPO	Ajánlott első DPIA esetén
Ügyvezető	Végső jóváhagyás és felelősségvállalás	Aláírás szükséges
NAIH	Opcionális előzetes konzultáció	Ajánlott, ha magas maradványkockázat

3.2 Mikor Kell Frissíteni?

Esemény	Kötelező Frissítés?
Évente	✅ Igen — rendszeres felülvizsgálat
Új adattípus bevezetése	✅ Igen
Új adatfeldolgozási cél	✅ Igen
Új harmadik feles vendor	✅ Igen
Data breach incidens után	✅ Igen
NAIH vizsgálat után	✅ Igen
Technológiai változás (pl. AI funkció)	✅ Igen

3.3 Tárolás

Szempont	Érték
Helye	`/docs/compliance/dpia/`
Hozzáférés	Vezetőség, HR admin, DPO
Verziókezelés	Git — előző verziók megőrzése
Archiválás	5 évig az elfogadás után

IV. NAIH SABLON — Kitöltve HR-ERP Adatokkal

4.1 Alapadatok

Mező	Érték
Adatkezelő neve	Housing Solutions Kft.
Székhelye	[Cím megadandó]
Adatkezelési tevékenység megnevezése	Munkavállalói jólléti monitoring és támogatási platform (HR-ERP Jólléti Platform)
Adatkezelés kezdete	2026. Q2 (tervezett éles indítás)
Érintettek köre	Housing Solutions Kft. munkavállalói (és leányvállalatai dolgozói)
Érintettek becsült száma	50-500 fő (skálázás tervezett)

Mező	Érték
DPIA készítésének dátuma	2026-03-18
DPIA készítője	[Név megadandó]
DPO / konzulens	[Név megadandó]

4.2 Adatfeldolgozás Összefoglalása

Az adatkezelés célja: A munkavállalók fizikai és lelki jóllétének proaktív monitorozása, korai jelzőrendszer kiégés és mentális egészségügyi problémák felismerésére, Employee Assistance Program (EAP) szolgáltatások biztosítása, szállásminőség és munkakörülmények hatásának elemzése.

Jogalap: GDPR 9. cikk (2)(a) — kifejezett hozzájárulás, kiegészítve GDPR 9. cikk (2)(b) — munkajogi kötelezettség (Mt. 166. §).

Adatkategóriák: Egészségügyi adatok (különleges kategória), személyes azonosító adatok, technikai/naplózási adatok.

4.3 Szükségességi Teszt

Kérdés	Válasz
Az adatkezelés alkalmas a cél elérésére?	Igen — napi pulzus + negyedéves felmérés klinikailag validált eszközökkel (MBI, UWES, WHO-5)
Van kevésbé invazív módszer?	Nem — papír alapú felmérés alacsonyabb részvételt eredményez, nincs korai felismerés
Az adatkezelés arányos a céllal?	Igen — csak szükséges adatokat gyűjtünk, nincs biometrikus adat, aggregáció min 5 fő
Az érintetteknek van választási lehetőségük?	Igen — explicit opt-in adattípusonként, bármikor visszavonható

4.4 Maradványkockázat Értékelés

A fenti mitigációs intézkedések végrehajtása után a maradványkockázat:

Kockázat	Eredeti Szint	Mitigáció Után	Elfogadható?
Adatszivárgás	Magas	**Alacsony**	✅ Igen
Hozzáférési hiba	Közepes	**Nagyon Alacsony**	✅ Igen
Re-identifikáció	Alacsony	**Nagyon Alacsony**	✅ Igen
Vendor kockázat	Közepes	**Alacsony** (DPA-kkal)	✅ Igen

Kockázat	Eredeti Szint	Mitigáció Után	Elfogadható?
AI előítélet	Közepes	**Alacsony** (felügyelettel)	✅ Igen
Consent hiány	Kritikus	**Nagyon Alacsony** (UI-val)	✅ Igen

Összesített maradványkockázat: ALACSONY — az intézkedések végrehajtása után a kockázat elfogadható szintre csökken.

4.5 Jóváhagyás

	Név	Beosztás	Dátum	
Készítette	_____	_____	_____	_____
Felülvizsgálta	_____	DPO / Konzulens	_____	_____
Jóváhagyta	_____	Ügyvezető	_____	_____

Következő felülvizsgálat dátuma: 2027-03-18 (vagy korábban, ha lényeges változás történik)

Dokumentum vége — DPIA v1.0 — HR-ERP Jólléti Platform Housing Solutions Kft. — 2026